AI Job Guide — Production Launch Readiness Audit

Date: 2026-11-02

Type: Read-only audit. No code, configuration, database records, or workflow definitions were modified. No migrations, deployments, commits, pushes, or secret rotations were performed. No n8n workflows were executed or activated. No real OpenAI calls or payment actions were made during this audit.

Scope: Full product — registration through matching, approvals, cover letters, and subscriptions. Not limited to AI workflows.

Method: Direct inspection of source code, SQL migrations, test files, CI configuration, and the live local n8n instance (via read-only MCP calls). Findings are separated into **Verified Implemented**, **Verified Gap**, and **Cannot Verify (requires dashboard/runtime access this environment does not have)**. Nothing here is inferred from documentation alone — every finding not marked "Cannot Verify" was confirmed against the actual current file or system state during this session.

This report supersedes narrative claims made in earlier chat-only sessions where they conflict with what is recorded here or in `docs/PRODUCTION_READINESS.md` (the living tracker, which this audit treats as the prior source of truth and extends, not replaces).

---

1. Executive Summary and Overall Readiness Assessment

AI Job Guide's core product logic — authentication, subscription/entitlement enforcement, Row Level Security, the matching pipeline, and the job-ingestion dedup layer — is **substantially sound and server-enforced**. No Critical-severity defect was found anywhere in this pass: no client-bypassable billing logic, no missing RLS, no exposed secret, no permissive CORS, no SQL injection surface, no evidence of real money or real email ever being sent without an explicit, honest UI disclosure.

What is missing is almost entirely **operational and go-to-market infrastructure**, not application logic:

- There is **no deployment/hosting configuration anywhere in the repository** — no Vercel config, no Dockerfile, no CI deploy step. There is currently no evidence of *where* this application would even run in production.
- There is **no error-tracking/APM service wired in** (no Sentry or equivalent dependency exists in `package.json`).
- The **privacy policy still contains a placeholder support email and has not been legally reviewed** — this is an explicit, pre-existing deployment blocker per this project's own engineering rules (AGENTS.md §34).
- **Account deletion is implemented and passes locally**, but has never been run against a real deployed environment, and the founder has not yet given final sign-off to expose it to real

users.

- The CI pipeline's **database-test job is not yet proven reliable on a real GitHub-hosted runner** and is explicitly non-blocking (`continue-on-error: true`) — so "tests pass" claims about this branch have only ever been demonstrated locally, never by CI for the DB suite.
- One n8n workflow — the **CV Analysis Worker** — is the single exception to "nothing AI-related is live": it is active today, polling every 5 seconds, and makes real OpenAI calls whenever a CV-analysis task is queued. This is believed to be intentional design (unlike the other 8 workflows, which are manual-trigger and confirmed inactive), but it has not previously been called out with this clarity in prior reports, and it is currently pointed at the local Docker Supabase instance only.
- A handful of stated MVP features (notably **admin job entry**) have no corresponding implementation at all.

Overall verdict: NO-GO for a public launch today. CONDITIONAL GO is achievable once the specific, mostly-non-code checklist in Section 8/9 is closed — none of the remaining items require new product features or architecture changes, and several (hosting config, error tracking, legal review, CI hardening) are standard pre-launch operational work rather than defects in the application itself.

---

2. Feature-by-Feature Readiness Matrix

Feature	Status	Basis
Landing page	**Ready**	Responsive classes present; `next/link` navigation confirmed; no client-rendering issues found
Signup / Login	**Ready**	Rate-limited (`reserve_auth_attempt`), OAuth redirect validated against open-redirect, browser-verified via Playwright in an earlier session
CV upload	**Partially Ready**	Works end-to-end; MIME/size validated at 3 layers; **server-side magic-number/content validation is Not Implemented** (Medium gap, pre-existing)
User preferences (incl. relocation/international gating)	**Ready**	Server RPC *and* a `BEFORE INSERT/UPDATE` trigger both independently enforce Pro-only fields — defense in depth confirmed this session
Admin job entry	**Not Ready — Not Implemented**	`requireAdmin()` helper exists but has **zero callers**; no `/admin` route exists anywhere. Listed as in-scope MVP in AGENTS.md §7 with nothing built
AI CV parsing (CV Analysis Worker)	**Partially Ready**	Functionally proven via real-AI validation; **this is the one workflow that is actually live/continuous today**; its OpenAI call node has no dedicated error-output branch (relies on a later stale-task sweep instead)
Job matching (embeddings + rerank)	**Ready for a bounded pilot**	Fixed and fully synced across `.ts` / `.json` /live n8n this session (511/511 workflow tests); inactive/manual-trigger; candidate-token secret must be confirmed present in production before any real matching traffic
Cover letter generation	**Ready for a bounded pilot**	Same caveats as above; inactive/manual-trigger; quota enforcement is a TypeScript read-then-decide, not a DB constraint (Low risk given today's manual-trigger-only concurrency)
Approve / reject flow	**Ready**	Playwright-covered; all loading/error/empty/success states explicitly handled in `ApplicationCard.tsx` / `CoverLetterCard.tsx`
Simple dashboard	**Ready**	Top-level and per-section loading/error states confirmed in `src/app/dashboard/page.tsx`
Subscriptions / plan limits (Free/Student/Pro)	**Ready**	Fully server-side, grant-restricted, no client-bypass path found; price-versioning/upgrade-locking logic matches its own documentation exactly when re-read from the current migration SQL
Real payment collection	**Not Ready — by deliberate design**	No real processor integrated; `UnconfiguredWhishProvider` throws on every operation; checkout UI is honest about "not available yet"
Account deletion	**Partially Ready**	Data-layer and reauthentication logic implemented and locally tested (unit/DB/workflow all green); **never run against a real deployed environment**; new E2E spec exists but has not yet been confirmed to pass by any recorded run; founder sign-off for production exposure is still pending

Feature	Status	Basis
Privacy policy	**Not Ready**	Live at `/privacy`, factually accurate about current system behavior, but still has a placeholder support email and has not had legal review — explicit deployment blocker per AGENTS.md §34
Job ingestion (15 provider adapters)	**Partially Ready**	Dedup is DB-constraint-backed, not just app logic; all adapters hardcode `applicationEmail: null` by design (URL-only applications); LinkedIn/Workday/JSearch/Adzuna remain disabled pending separate pilot approval per AGENTS.md §35
Multi-location matching	**Implemented, locally tested — not yet approved for deployment** (per existing memory/tracker record)	—
Error tracking / monitoring	**Not Ready — Not Implemented**	No Sentry/Datadog/APM dependency anywhere in `package.json`
Deployment / hosting infrastructure	**Not Ready — Not Implemented**	No Vercel config, Dockerfile, or any platform-specific deployment file exists in the repository
Admin/incident operational tooling	**Not Ready**	No runbook, no health-check endpoint, no admin UI

---

3. Security and Privacy Findings

Verified Implemented

- **RLS is correctly enabled and scoped on every private/internal table checked** (15+ tables: `profiles`, `cvs`, `job_preferences`, `jobs`, `job_locations`, `applications`, `cover_letters`, `cv_analyses`, `subscriptions`, `payment_attempts`, `matches`, `audit_events`, `price_versions` / `plan_prices`, `registry_sync_staging`, `source_intelligence`, `rate_limit_events`). No `USING (true)` policy was found on any privately-owned table. `price_versions` / `plan_prices` intentionally use `USING (true)` for `SELECT` only — a public price catalog, correct by design. `registry_sync_staging` / `source_intelligence` have RLS enabled with **zero** grants to `authenticated` / `anon` — effectively deny-all for client roles, service-role-only, correct.
- **Storage is private and correctly path-scoped**: the `cvs` bucket is `public:false`, 5MB limit, MIME allowlist; all 4 object policies require `auth.uid()::text = (storage.foldername(name))[1]`; no `anon` grant exists at all.
- **Every internal worker API route validates its Bearer secret before touching the request body or the database** — confirmed across all 14 routes under `src/app/api/internal/**`.
- **Candidate-token binding is real**: `save-rerank-results` never trusts a client-supplied `(cvAnalysisId, jobId)` pair directly; it requires `MATCHING_CANDIDATE_TOKEN_SECRET` and fails

closed if that secret is unset.

- **No webhook endpoint exists anywhere in the repo** — consistent with no real payment processor being configured. This is not a current defect (there is nothing live to attack), but it means webhook signature verification is **entirely unbuilt** and must be implemented fresh — not merely reviewed — before any real payment integration goes live.
- `.env.example` documents every required variable with no real values and explicit server-only/fail-closed guidance. No secret environment variable is referenced from any `"use client"` file.
- **Security headers are solid**: `X-Content-Type-Options: nosniff`, `X-Frame-Options: DENY`, `frame-ancestors 'none'`, a locked-down `Permissions-Policy`, and HSTS sent only over real HTTPS outside dev. No `Access-Control-Allow-Origin` header exists anywhere in the codebase — no permissive CORS on any API route.
- **Database-level rate limiting exists independent of the app-layer limiter**: CV replacement and AI-feedback-task creation are both throttled by dedicated RPCs (`replace_cv()`, `charge_feedback_task_quota()`) backed by a `rate_limit_events` table — this holds regardless of which route calls them. Most auth-flow routes (login, signup, password reset/update, OAuth init/callback, account reauthentication) are confirmed wired to the shared rate-limit policy table.

Verified Gap

- `POST /api/account/delete` **has no app-layer or DB-layer rate limit** — only a fresh-session check and a literal `"DELETE"` confirmation guard. Low practical abuse value (the action is self-destructive and requires a genuinely fresh authenticated session), but it is a real gap against this project's own blanket rate-limiting rule (AGENTS.md §27). **Severity: Low-Medium.**
- `src/app/api/cv-analysis/submit-feedback/route.ts` **and its sibling routes show no app-layer rate-limit import** in a directory-level grep. The DB-level feedback-task quota RPC may already cover the costly path, but this was not independently confirmed down to that specific route in this pass. **Severity: Medium — needs one targeted follow-up read before this is closed out.**
- **Server-side file-content/magic-number validation for CV uploads remains Not Implemented** — MIME type and extension checks exist at three layers (client, Storage bucket, RPC), but none inspect actual file bytes. This is a pre-existing, already-tracked finding, reconfirmed unchanged this session. **Severity: Medium.**
- **Webhook signature verification is entirely unbuilt** (see above) — not a defect today, but a hard prerequisite before any real payment provider is wired in. **Severity: Medium, timing: before payment activation, not before this launch.**

Cannot Verify

- Whether live-project RLS in a deployed Supabase project actually matches the migration source (no deployed/production project is reachable from this environment).
- Production SMTP configuration, Supabase Point-in-Time-Recovery status and restore-drill results, and `main` branch-protection rules — all dashboard-side or GitHub-settings-side,

outside this repo's reach.

---

4. Subscription and Business-Rule Compliance Findings

No Critical or High-severity finding exists in this area. Enforcement is consistently server-side and grant-restricted.

Verified Implemented

- The plan catalog (`public.plans`) is server-authoritative: RLS grants `SELECT` only to `authenticated` , with no `INSERT` / `UPDATE` / `DELETE` grant to any client role. Current limits: Free 1 match/1 letter, Student 45/8, Pro 95/15.
- **Job-match quota** is enforced inside a `SECURITY DEFINER` RPC that derives the user from `auth.uid()` (never a client-supplied id) and reads the plan limit dynamically; the `matches` table itself grants `SELECT` -only to `authenticated` , so a direct client insert is rejected by the database regardless of any application-layer check.
- **Cover-letter quota** is similarly unreachable by a direct client write (`cover_letters` grants are `SELECT` -only to `authenticated`); generation only happens through the service-role-driven worker path where the quota check lives. One narrow gap: this specific check is a read-then-decide in TypeScript rather than a DB constraint, so two concurrent worker runs for the same user could theoretically both read the same "remaining" count before either writes — low real-world exposure today since the cover-letter worker is manual-trigger-only, not concurrently scheduled. **Severity: Low.**
- **Relocation-market and international-search Pro-gating is enforced at the database trigger level**, not only inside the `save_job_preferences` RPC — a `BEFORE INSERT OR UPDATE` trigger on `job_preferences` itself (and matching triggers on its two child tables) independently re-validates the user's plan on every write path. This matters because `authenticated` does hold a direct `INSERT/UPDATE/DELETE` grant on `job_preferences` — a client *could* call the Supabase client directly instead of the RPC, but the trigger still blocks a non-Pro user from setting `international_search_enabled = true` regardless of which path was used.
- **No client-supplied plan name, price, or billing-period value is ever trusted.** `mark_payment_verified` 's current SQL (re-read directly from the live migration file this session, not assumed from documentation) derives the billing period server-side from `purchase_type` and the attempt's own locked price-version/billing-period — exactly matching the early-renewal-deferral and upgrade-locking behavior `docs/PRODUCTION_READINESS.md` already documents.
- **No real payment processor exists; no fake "successful payment" is possible.** `UnconfiguredWhishProvider` throws on every one of `createCheckout` / `getPaymentStatus` / `verifyPayment` / `handleProviderNotification` — confirmed current by reading the file directly, not by trusting the prior record.

Verified Gap

- General preference-field business rules (role count 1–5, location required for onsite work, roles/locations must reference active catalog rows) are validated only inside the `save_job_preferences` RPC, not as table constraints or triggers. Because `authenticated` can write to `job_preferences` directly, a user could in principle write a malformed-but-harmless preferences row (e.g., zero target roles) that bypasses this specific validation — it does **not** bypass any plan/billing entitlement, since the Pro-gating trigger always fires. **Severity: Low — data-integrity nuisance, not a security or billing issue.**

---

5. Infrastructure and Deployment Readiness

Verified Implemented

- The required CI job (`quality-checks` in `.github/workflows/ci.yml`) runs lint, `tsc --noEmit` , `test:unit` , `test:workflow` , and `build` , and is **not** marked `continue-on-error` — it genuinely blocks a merge on failure.
- Fail-fast environment validation exists per-module (`src/lib/supabase/env.ts` , `src/lib/supabase/admin.ts` throw at first access if a required var is missing), and every internal worker route checks its own Bearer secret inline. There is no single centralized "validate everything at boot" checkpoint, but every required var is validated somewhere before it would ever be used unsafely.
- 110 migrations exist, all forward-only — no down-migration files found, consistent with this project's documented migration strategy.
- Indexes exist on the hot, user-scoped query paths that matter today: matches, applications, cv_analyses, analysis_tasks, cover_letters, and jobs' geography/closing-date/source-id columns are all indexed.
- `src/lib/authz/requireAdmin.ts` is a soundly designed admin-authorization helper — re-derives the user server-side and checks a DB-side `is_admin()` RPC rather than trusting any client claim.

Verified Gap

- **The `db-tests` CI job spins up a real ephemeral Supabase/Docker instance and runs the full DB suite, but is explicitly marked `continue-on-error: true` .** Its own in-repo comment states it has "NOT YET VALIDATED BY A REAL CI RUN." This means every "all tests passing" claim about this branch has only ever been demonstrated on a local machine — CI itself cannot currently catch a DB-test regression before merge. **Severity: Medium**, matches and reconfirms the existing tracker finding.
- **No deployment/hosting configuration exists anywhere in the repository.** No `vercel.json` , no Dockerfile, no other platform config — only `next.config.ts` (framework config, not a deployment target). There is currently no evidence of where this application would actually run in production. **Severity: High for launch readiness** — this blocks

every other "verify in production" step in this report, since there is no production environment to verify against yet.

- **"Admin job entry" (an explicitly in-scope MVP feature per AGENTS.md §7) has no implementation at all.** `requireAdmin()` has zero callers anywhere in `src/`; no `/admin` route exists. **Severity: High** relative to the project's own stated MVP completeness claim — either this needs to be built, or the MVP scope documentation needs to be corrected before calling the MVP "done."
- **No health-check endpoint exists** (`/api/health` or equivalent). **Severity: Medium.**
- **No incident-response runbook exists** in `docs/` — unchanged since the original 2026-08-21 finding. **Severity: Medium.**
- **No external error-tracking/APM dependency exists anywhere in `package.json`.** Only Supabase/Next/React in production dependencies; only Playwright/ESLint/Tailwind/TypeScript/Supabase-CLI in dev dependencies. **Severity: High** — this is the single biggest operational blind spot for a real launch: a production failure today would be visible only in raw server logs, if at all.

Cannot Verify

- Point-in-time recovery status and restore-drill results (Supabase dashboard-side).
- `main` branch protection rules (no `gh`/GitHub API access from this environment).

---

6. AI Workflow and Data-Quality Readiness

Verified Implemented

- All **9** n8n workflow source pairs under `n8n-workflows/` were inventoried (the prior tracker named only 2): `01-job-ingestion`, `02-job-matching`, `03-cover-letter-generation`, `cv-analysis-worker`, `error-handler`, `job-expiry-sweep`, `job-ingestion-pilot-orchestrator`, `registry-sync`, `source-intelligence-analyzer`. Every `.json` source has `"active": false`, and the live local n8n instance confirms the same `active:false` / `triggerCount:0` state for all of them **except two, both by design**: the reusable `AI Job Agent - Error Handler` sub-workflow (attached via `errorWorkflow` setting, never self-triggers) and `01 Job Ingestion`'s daily schedule node, which exists and is wired but the parent workflow itself remains fully inactive until a human reviews a run.
- `job-expiry-sweep` exists only as versioned source — it has never been imported into the running n8n instance at all.
- **Deduplication is backed by a real database unique constraint** (`jobs_dedup_scope_external_id_key`), not application logic alone — confirmed by reading both the migration and `ingestSourceBatch.ts`'s use of it.
- The AI test-isolation mechanism (`src/lib/matching/aiTestIsolation.ts`) was re-confirmed default-off this session: no relevant environment variables are set, and `parseIdAllowlist` returns `null`.

- A spot-check of `docs/PRODUCT_MATCHING_RULES.md` against `checkJobEligibility.ts` found no mismatch in the 3 rules checked (physical-presence eligibility function exists as named; the "never infer onsite/hybrid/remote from city" rule matches actual code behavior).
- The Job Matching workflow fix applied earlier this session (dedicated `Log Prepare Rerank Failure` terminal node, preventing a bogus item from entering the per-candidate retry loop on a whole-batch failure) is now provably identical across the `.ts` source, the `.json` source, and the live n8n instance, with `tests/workflow` at 511/511 after the necessary test update.

Verified Gap

- **The CV Analysis Worker is the one real exception to "nothing AI-related is live" — it is active today**, scheduled to poll every 5 seconds, and genuinely calls `api.openai.com` whenever it claims a queued analysis task. This is believed to be intentional design — unlike the other 8 workflows, this one is meant to run continuously rather than be manually triggered — but **no prior report in this project's history has flagged this distinction clearly**; language like "all workflows are inactive/manual-trigger-only" used elsewhere could lead a reader to wrongly assume zero live AI spend risk exists today. Its target (`http://supabase_kong_ai-job-agent:8000`) is confirmed local-Docker-only, so there is no production exposure yet — but this must be explicitly re-reviewed, not assumed safe, at the moment of any production deployment. **Severity: Medium — a documentation-accuracy and operational-awareness gap, not a current production risk.**
- **The CV Analysis Worker's OpenAI call node (`Call OpenAI1`) has `continueOnFail: true` but no dedicated error-output node or branch**, unlike the explicit `Log Rerank Failure` / `Log Prepare Rerank Failure` pattern just applied to the Job Matching workflow. A failed call falls through silently into response parsing; recovery depends entirely on a later stale-task-sweep RPC catching it, rather than an immediate, visible failure log. **Severity: Medium.**
- Whether a token/output-size cost ceiling is actually set on this worker's OpenAI request body was **not fully confirmed** — the body is built dynamically in an upstream Code node that was not inspected in this pass. This should be read and confirmed before treating this worker's cost exposure as fully characterized.

Cannot Verify

- Real production cost behavior at scale (no production traffic exists yet to measure).

---

7. Missing Tests and Operational Risks

Verified Implemented/Good

- Test breadth is substantial: **75 unit test files, 65 DB test files, 12 workflow test files, 7 Playwright E2E spec files.** Every major feature named in this audit's scope (CV upload, matching, cover letters, approve/reject, billing/subscriptions, account deletion) has at least unit **and** DB coverage.

- All four UI states (loading, error, empty/blocked, success) are explicitly handled in the dashboard's core components (`ApplicationCard.tsx` , `CoverLetterCard.tsx` , `src/app/dashboard/page.tsx`).
- No clickable- `<div>` -as-button anti-pattern exists anywhere in `src/` — every `onClick` sits on a real `<button type="button">` or a `<Link>` / `<a>` . `window.location` is used only for OAuth redirect-origin construction, never for internal navigation.
- Accessibility basics are broadly, not just spottily, present: every custom `outline-none` usage is paired with a `focus:` / `focus-visible:` ring replacement; no raw `<img>` tags exist outside `next/image` usage.
- A new, previously-missing E2E spec for the account-deletion flow now exists (`tests/e2e/account-deletion.spec.ts`), covering 5 real scenarios: happy-path delete, wrong-confirmation blocks deletion, unauthenticated 401, wrong-confirmation 400, and reauthentication rate-limiting.

Verified Gap

- **Playwright is configured for a single browser project (Desktop Chrome / Chromium) only** — there is no WebKit, Firefox, or real mobile-viewport project configured. Given the breadth of responsive Tailwind usage across the app, this means **no actual cross-browser or mobile-device behavior has ever been automatically verified**, despite the app being designed to support it. **Severity: Medium.**
- **Three E2E spec files are new/untracked and have not yet been confirmed to pass by any recorded run** (`account-deletion.spec.ts` , `cover-letter-evidence.spec.ts` , `dashboard-screenshots.spec.ts`). `docs/PRODUCTION_READINESS.md` Phase 4 still explicitly states "NOT run: Playwright E2E for this flow" for account deletion. This is a documentation/reality gap that should be closed by actually executing these specs (which this read-only audit deliberately did not do, since it would create/delete real fixture users) before claiming the flow is E2E-verified. **Severity: Medium.**
- The account-deletion E2E spec's own header comment documents that it **cannot** exercise either the password-reauthentication form under a stale session or a real Google OAuth reauthentication round-trip — both remain genuinely unverified by any automated test. **Severity: Medium**, consistent with the account-deletion row in Section 2.
- Candidate-token replay, long-running-batch TTL exposure, TOCTOU, and stale-saved-match limitations remain accepted, documented risks (per `candidateToken.ts` 's own header comment) rather than solved — appropriate for today's pilot scale, but a genuine concern "before high production matching volume," per the existing tracker language. **Severity: Medium, timing-gated, not an immediate blocker.**

Cannot Verify

- Whether the three new/untracked E2E specs actually pass (not executed in this read-only pass).
- Real mobile-device or assistive-technology behavior beyond static code inspection — no live device or screen-reader testing evidence exists in the repo.

---

8. Prioritized Launch Blockers and Concrete Remediation

Ordered by severity, then by how directly each item blocks a real user from being safely exposed to the product.

High — true launch blockers

1. **No deployment/hosting configuration exists.**

Fix: Decide a hosting target (the stack is plain Next.js App Router + Supabase, compatible with Vercel or any Node-capable host). Add the minimal platform config, document every required environment variable against the real production Supabase project, and perform one full build+deploy dry run before any user traffic.

2. **No error-tracking/APM service is wired in.**

Fix: Add one error-tracking SDK (e.g. Sentry) to server and client error boundaries, pointed at a free/low tier initially. Wire existing safe `console.error` call sites into it per AGENTS.md §19. This is the single highest-leverage fix for being able to detect a real production incident at all.

3. **Privacy policy still has a placeholder support email and no legal review.**

Fix: Have the founder supply a real support contact and have counsel (or at minimum a careful non-legal self-review against actual data practices) sign off on `/privacy` before this is treated as final. This is an explicit, pre-existing deployment blocker already recorded in AGENTS.md §34 — not a new finding, but still open.

4. **Account deletion has never been run against a real deployed environment, and founder production sign-off is still pending.**

Fix: After a hosting target exists (#1), deploy to a staging-like environment, execute the new `account-deletion.spec.ts` E2E suite against it, and obtain explicit founder approval before this flow is reachable by real users, per AGENTS.md §11's own activation checklist.

5. **"Admin job entry" is a stated MVP feature with zero implementation.**

Fix: Either build a minimal admin job-creation route gated by the existing (already-correct) `requireAdmin()` helper, or explicitly amend the MVP-scope documentation to remove this claim before describing the MVP as complete. The smaller, faster fix is the documentation correction; the helper already exists if the feature is wanted later.

6. **The `db-tests` CI job has never been proven reliable on a real GitHub-hosted runner and does not block merges.**

Fix: Run the existing job as-is (no code change needed) and watch it on a real GitHub Actions run; once a few consecutive clean runs are observed, remove `continue-on-error: true` so it becomes a required check, matching the `quality-checks` job's status.

Medium — should close before public launch, but narrower in scope

7. **Server-side CV file-content (magic-number) validation is not implemented.** Add a lightweight signature check (e.g. verify the PDF magic bytes) in the existing upload path alongside the current MIME/size checks — no architectural change needed.

8. **The CV Analysis Worker's OpenAI call node has no dedicated error-output branch**, and its real continuous-polling nature was not previously flagged with this clarity. Before any production deployment: (a) add a `Log Call OpenAI Failure`-style terminal node mirroring the Job Matching fix pattern, (b) explicitly confirm its Supabase target will be swapped to production only after deliberate review, and (c) confirm a token/cost ceiling exists on its request body.

9. **No health-check endpoint exists.** Add a minimal `/api/health` route — a few lines, no dependency needed.

10. **No incident-response runbook exists.** Write a one-page runbook: who gets paged, where logs/errors are visible once #2 is wired in, and the rollback procedure for a bad deploy or migration.

11. **`/api/account/delete` and the `cv-analysis/submit-feedback` route's rate-limiting status should be closed out** — add the standard rate-limit call to the former; do one targeted read of the latter to confirm its DB-level quota RPC is actually what gates it before calling this closed.

12. **Webhook signature verification is entirely unbuilt.** No action needed before this launch (no payment processor is live), but this must be built — not just reviewed — before any real Whish/payment integration is activated.

13. **Confirm via dashboard, not code, before launch:** Supabase PITR is enabled and a restore has actually been tested; production SMTP is configured; `main` branch protection requires the `quality-checks` job; live-project RLS matches migration source.

Low — safe to defer past initial launch

- Expand Playwright coverage to WebKit/Firefox/a real mobile viewport.
- Add a DB-level guard against the theoretical concurrent-cover-letter-quota race (currently a TypeScript read-then-decide) if the cover-letter worker ever moves off manual-trigger.
- Add table-level constraints for the general preference-field business rules currently enforced only inside the `save_job_preferences` RPC.
- Load-test worker throughput once real traffic exists.
- Revisit the candidate-token replay/TOCTOU checkpoint before high production matching volume.

---

9. Phased Action Plan

Before Launch

- ☐ Decide and configure a real hosting target; document and validate every required production environment variable
- ☐ Wire an error-tracking/APM service into both server and client error paths
- ☐ Fill in a real support email and get legal (or thorough founder) review of `/privacy`
- ☐ Deploy to a staging-like environment and run the new account-deletion E2E suite against it; get explicit founder sign-off before exposing the flow to real users

- ☐ Resolve the "admin job entry" MVP gap — either build the minimal route or correct the MVP documentation
- ☐ Watch `db-tests` pass cleanly on a real GitHub Actions run, then make it a required check
- ☐ Add CV magic-number validation
- ☐ Add a dedicated error-output node to the CV Analysis Worker's OpenAI call, confirm its cost ceiling, and explicitly review its production target before any deployment
- ☐ Add a `/api/health` endpoint and a one-page incident-response runbook
- ☐ Add rate limiting to `/api/account/delete`; confirm `cv-analysis/submit-feedback`'s rate-limit coverage
- ☐ Confirm via the relevant dashboards (never by printing values here): production SMTP, Supabase PITR + a tested restore, `main` branch protection, live RLS parity

Launch Day

- ☐ Verify homepage, auth, dashboard, and CV upload render correctly against the real production environment
- ☐ Perform one controlled, bounded smoke-test execution of each n8n workflow before enabling any schedule/continuous trigger in production — starting with the CV Analysis Worker, since it is designed to run continuously
- ☐ Keep LinkedIn/Workday/JSearch/Adzuna ingestion disabled; they remain gated behind a separate, explicit pilot-approval process per AGENTS.md §35
- ☐ Monitor the newly-wired error-tracking dashboard and n8n execution log closely for the first 24–48 hours

After Launch

- ☐ Run an actual backup-restore drill against production, not just confirm PITR is "enabled"
- ☐ Load-test worker throughput once real traffic volume exists
- ☐ Expand Playwright to cover additional browsers and a real mobile viewport
- ☐ Revisit the candidate-token replay/TOCTOU checkpoint before matching volume grows significantly
- ☐ Build a real payment processor integration and genuine webhook signature verification only once a provider is actually approved
- ☐ Reconsider the explicitly-deferred development-secret rotation whenever convenient — not urgent, but still open

---

10. Recommendation: NO-GO (today) / CONDITIONAL GO (once the Before-Launch checklist above closes)

The application's **business logic, data model, and security posture are launch-grade** — RLS, Storage policies, billing enforcement, and the matching/ingestion pipelines all held up to direct inspection with no Critical findings. What is not launch-ready is almost entirely the **operational scaffolding around the product**: nowhere to deploy it, no way to observe it

once deployed, an unfinished privacy/legal step, and a handful of CI and test-coverage claims that have only ever been demonstrated locally rather than proven in the environment that will actually gate real deployments.

None of the items in Section 8's High tier require new product features, a schema change, or an architecture decision — they are standard pre-launch operational work. Once they are closed, this project is in a strong position for a **small, controlled pilot launch** (not yet a full public one, given the still-pending candidate-token replay/TOCTOU and multi-location-matching production-approval items noted elsewhere in this project's own tracker).

Do not implement any of the fixes above until the founder has reviewed this report and approved a specific scope and order.